

## Technical Note

# Austrian University DPIA Generator for AI Systems

**Version:** 0.3

**Author:** Peter Holubar

**ORCID:** 0000-0003-1613-6466

**Institution:** BOKU University Vienna

**License:** MIT License

**Recommended Zenodo resource type:** Technical Documentation / Report (not Software)

---

## Abstract

The Austrian University DPIA Generator for AI Systems is an open framework that supports the structured creation, review, and improvement of Data Protection Impact Assessments (DPIAs) for artificial intelligence systems deployed in higher education and research environments.

The framework was developed in response to the growing adoption of generative AI, AI assistants, agentic systems, and AI-enabled collaboration platforms within universities. While numerous DPIA templates exist, most are designed for generic organisational settings and do not adequately address the specific legal, organisational, and governance requirements of universities — in particular the interaction between data protection law, labour relations law, and academic freedom.

The framework combines requirements arising from the General Data Protection Regulation (GDPR), Austrian data protection law (including the Austrian DPIA Ordinance and DPIA Exemption Ordinance), the Austrian Labour Constitution Act (Arbeitsverfassungsgesetz, ArbVG), research governance principles, and the European Union Artificial Intelligence Act (Regulation (EU) 2024/1689).

---

## 1. Background and Motivation

### 1.1 Why this project was created

Austrian universities have, within a short period, moved from evaluating individual AI tools on a case-by-case basis to facing AI capabilities embedded across entire collaboration platforms — search and knowledge assistants (e.g. Atlassian Rovo), meeting and video-conferencing assistants (e.g. Zoom AI Companion), and office productivity suites. In each case, the underlying processing increasingly relies on federated architectures, in which a primary platform vendor dynamically routes data to one or more third-party foundation model providers (e.g. OpenAI, Anthropic, Google).

This shift created a practical problem for data protection officers (DPOs) and works councils at universities: existing DPIA templates were written before this architecture became common, and generic templates from commercial vendors or consultancies typically:

- treat "the AI system" as a single black box, without distinguishing the roles of platform vendor, sub-processors, and model providers;
- do not address the Austrian Labour Constitution Act, under which the introduction of systems capable of monitoring employee behaviour or performance requires a works

agreement (*Betriebsvereinbarung*) — a requirement with no direct equivalent in many other EU member states' templates;

- do not address academic freedom and research security as a distinct risk dimension, even though university AI deployments routinely process research data, grant applications, peer reviews, and collaboration agreements subject to confidentiality and export-control obligations;
- treat the EU AI Act, where addressed at all, as a subordinate add-on to the DPIA rather than as a parallel governance process with its own legal basis (Art. 27 AI Act, fundamental rights impact assessments) and its own competence requirements (Art. 4 AI Act).

The framework was developed to close this gap: to provide a DPIA structure that treats these university-specific and Austria-specific requirements as integral parts of the assessment, not as optional appendices.

## 1.2 The problem the framework solves

When large language models are used to assist in drafting governance documents such as DPIAs, a specific failure mode arises: the output *looks* complete — structured, well-formatted, citing the right legal provisions — while in fact resting partly on plausible-sounding but unverified or fabricated claims about vendor behaviour, sub-processor relationships, data retention periods, or training-data policies. A DPIA produced this way is worse than no DPIA at all, because it creates a false sense of due diligence.

The framework addresses this failure mode directly, by:

1. providing a fixed structure that ensures the relevant Austrian- and university-specific risk dimensions are systematically addressed for *every* AI system, regardless of how "harmless" the system initially appears;
2. embedding an epistemic discipline (see Section 3) that forces every factual claim to be labelled according to its evidentiary status, and that treats missing information as a documented gap rather than as something to be silently filled in;
3. providing a review mode that can be applied to DPIAs not produced with this framework, to identify the same recurring categories of gaps.

## 1.3 What the framework leverages

The framework is implemented as a system prompt for large language models (tested with general-purpose conversational AI assistants). It does not require special software, APIs, or infrastructure beyond a capable LLM with — ideally, but not necessarily — web search access. Where web search is unavailable, the framework requires this limitation to be disclosed and the affected fields to be marked as unresolved rather than estimated.

## 2. Purpose

The primary objective of the framework is to provide a transparent and reproducible structure for DPIA drafting and review processes involving AI systems at universities.

The framework is intended to:

- support Data Protection Officers and compliance professionals in producing a first structured draft that already reflects Austrian- and university-specific legal requirements;
- facilitate interdisciplinary governance processes by making explicit which questions belong to which competent body (DPO, works council, IT security, research support, institutional governance board);
- improve the transparency of AI-related risk assessments by separating documented facts from vendor claims, expert assessments, and open questions;
- identify documentation gaps systematically, both in newly generated drafts and in existing DPIAs submitted for review;
- support institutional decision-making by providing a differentiated final recommendation (e.g. conditional approval for a limited pilot vs. no approval for HR-related use cases) rather than a binary outcome;
- provide a consistent assessment methodology across heterogeneous AI systems — document-search assistants, meeting assistants, agentic workflow tools, and others — so that comparable systems are evaluated against comparable criteria.

The framework is particularly suited for universities, research institutions, and other public-sector organisations operating in complex, multi-stakeholder governance environments, where a single processing activity routinely touches data protection law, labour relations law, research governance, and emerging AI-specific regulation at the same time.

---

## 3. Methodological Principles

The framework is based on five methodological principles:

4. **Transparency before certainty.** Uncertainties are stated explicitly rather than smoothed over for readability.
5. **Explicit treatment of uncertainty.** Every substantive claim is assigned an evidentiary status, rather than being presented in a uniform, undifferentiated narrative voice.
6. **Source-based reasoning and traceability.** Where a claim is marked as documented evidence, the framework requires the underlying source (document name, section or page, or URL, plus retrieval date where applicable) to be stated alongside it.
7. **No fabrication of missing information.** Fields for which the required information lies exclusively with the institution (e.g. internal responsibilities, contractual details, dates) are never filled with invented values, including for illustrative purposes.
8. **Separation of documented facts, manufacturer claims, expert assessments, and unresolved issues.** These four categories are kept visually and textually distinct throughout the document.

### 3.1 Source status labels

To operationalise these principles, every factual statement is assigned one of four source status labels:

| Label                  | Meaning                                                                                                                                       |
|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Documented evidence    | Verifiable from a contract, data processing agreement, or an official, independent source, cited with document/section/URL and retrieval date |
| Manufacturer statement | Drawn from vendor documentation, not independently verified                                                                                   |
| Assessment             | A plausible inference from available information, not otherwise substantiated                                                                 |
| Unclear                | Information is missing, contradictory, or could not be verified (e.g. because no web search tool was available)                               |

A statement may carry only one label — the least certain applicable label governs. Risk scores (probability and severity) generated by the framework are always treated as **provisional assessments**, pending confirmation by the competent institutional bodies.

This approach is intended to reduce the risk of false certainty when AI systems are used to assist in producing governance documentation, and to make the resulting document auditable: a reviewer can immediately see which statements require independent verification before the DPIA can be approved.

## 4. Scope

The framework supports:

- creation of new DPIA drafts, either from an existing AI fact sheet (e.g. produced using the companion AI Assessment Framework) or from a free-text system description;
- review of existing DPIAs, including a section-by-section gap analysis against the framework's reference structure;
- AI-specific risk assessments, including a minimum set of risks that must be considered for every system (e.g. hallucination/false information risk, shadow IT, training-data repurposing, re-identification via activity logs);
- governance-oriented documentation, including an explicit mapping of roles and responsibilities (who assesses, who decides, who bears the residual risk);
- preparation of institutional approval procedures, including a differentiated final recommendation structure distinguishing pilot-phase approval from full approval and from non-approval for sensitive use cases.

The framework includes dedicated assessment sections covering:

- legal basis and purpose limitation under Art. 6 GDPR, including a critical treatment of "legitimate interest" as a basis for public-sector bodies;
- categories of personal data and data subjects, including students, staff, and external collaborators;
- third-country transfers and a transfer-impact assessment approach informed by the *Schrems II* line of case law and the EDPB's Recommendations 01/2020, without treating any single transfer mechanism (SCCs, the EU–US Data Privacy Framework, or otherwise) as schematically sufficient;
- technical and organisational measures;
- AI-specific risk patterns, including a mandatory, free-standing risk for hallucinated or otherwise incorrect AI-generated outputs;
- joint controllership and processor relationships in multi-tier vendor architectures (platform vendor plus one or more foundation model sub-processors);
- prompt governance and data minimisation at the input stage, distinct from general retention schedules;
- special categories of data under Article 9 GDPR, with university-specific scenarios (sick leave, equality proceedings, workplace conflict, works council matters, whistleblowing);
- academic freedom and research security, including risks to unpublished research, patentability, non-disclosure obligations, and export control;
- employee monitoring and works council participation under the Austrian Labour Constitution Act (§ 96 and § 96a ArbVG), including cases where the monitoring capability arises from the underlying platform rather than from the AI feature itself;
- human oversight requirements informed by Art. 14 of the EU AI Act;
- AI Act governance considerations, including GPAI classification, high-risk classification under Annex III, the conditional need for a fundamental rights impact assessment under Art. 27, and AI literacy obligations under Art. 4.

---

## 5. Relationship to the AI Assessment Framework

The DPIA Generator forms part of a broader governance ecosystem and is designed as a **companion module** to the AI Assessment Framework (Holubar, 2026, DOI: 10.5281/zenodo.20258614). The two frameworks share the same methodological principles (source status labels, transparency, separation of facts from assessments) and a common goal — supporting, not replacing, institutional AI governance — but serve different stages of the assessment process.

A recommended assessment sequence is:

9. **AI System Assessment** — initial triage and best-practice comparison using the AI Assessment Framework.
10. **AI Fact Sheet** — structured system identification (Module D of the AI Assessment Framework), documenting architecture, data flows, and known risks.
11. **DPIA Generation and Review** — using this DPIA Generator, either to produce a full draft from the fact sheet or to review an existing DPIA against the reference structure.
12. **Fundamental Rights Assessment** (where required) — for systems identified as high-risk under Annex III of the EU AI Act, corresponding to Module E of the AI

Assessment Framework. The DPIA Generator explicitly flags when this step may be required but does not produce its content.

13. **Institutional Approval Process** — final decision by the competent institutional bodies (data protection officer, works council, IT security, governance board), informed by, but not determined by, the outputs of steps 1–4.

The DPIA Generator is therefore intended to **complement, rather than replace**, broader AI governance activities. It produces a structured working document that feeds into, but does not conclude, the institutional decision-making process.

---

## 6. Limitations

The framework does not provide legal advice.

It does not replace the responsibility of Data Protection Officers, legal departments, works councils, ethics committees, university management, or other competent bodies.

The framework cannot determine compliance automatically and cannot approve or reject AI systems. Any approval/conditions language produced by the framework is explicitly framed as a *recommendation* for consideration by the competent bodies, not as a decision.

The framework depends on the quality and availability of input information. Where web search or document access is unavailable, or where contractual documents (data processing agreements, sub-processor lists) are not provided, the corresponding sections are marked as unresolved rather than estimated — meaning that a DPIA draft produced under such conditions will necessarily contain a larger number of open items, by design.

All final decisions remain the responsibility of the respective institution.

---

## 7. Intended Audience

The framework is intended for:

- Data Protection Officers;
  - legal departments;
  - compliance officers;
  - AI governance teams;
  - works councils (Betriebsräte);
  - information security professionals;
  - research support units;
  - project leaders introducing AI systems at universities and research institutions.
-

## 8. Versioning and Provenance

Version 0.3 reflects three rounds of structured peer feedback from the perspective of an Austrian university data protection officer, applied iteratively to an initial draft (v0.1):

- **v0.1 → v0.2:** introduced an explicit tool-availability check (preventing the framework from claiming web searches that were not performed), a source-citation requirement for “documented evidence” labels, provisional-status labelling of risk scores, an explicit separation of the GDPR DPIA from the EU AI Act assessment as parallel rather than nested processes, a refined (non-schematic) treatment of *Schrems II* / Data Privacy Framework transfer mechanisms, and a broadened Austrian Labour Constitution Act analysis covering platform-level monitoring capabilities, not only AI-feature-level ones.
- **v0.2 → v0.3:** added a roles-and-responsibilities table; an explicit Austrian DPIA Ordinance (BGBl. II No. 278/2018) threshold check alongside the WP248 criteria; a dedicated section on joint controllership and processor relationships in multi-tier vendor architectures; a dedicated section on prompt governance and input-side data minimisation; a dedicated human-oversight section informed by Art. 14 EU AI Act; a conditional fundamental-rights-impact-assessment flag; and three mandatory questions operationalising the Art. 36 GDPR prior-consultation decision.

The framework has been applied, as a worked example, to AI systems including Atlassian Rovo and Zoom AI Companion, in both cases producing full DPIA drafts that surfaced multi-tier sub-processor questions, Austrian Labour Constitution Act implications, and — in the case of meeting assistants — a qualitative shift from ephemeral spoken communication to persistent, searchable records as a distinct risk driver.

---

## 9. AI Assistance Statement

In keeping with the framework's own principle of transparency before certainty, the use of AI tools in producing this framework and this technical note is disclosed here.

Claude (Anthropic) was used to draft and iteratively revise the system prompt constituting the DPIA Generator (versions 0.1–0.3), to generate worked-example DPIA drafts (Atlassian Rovo, Zoom AI Companion) used to test the framework's structure, and to draft this technical note.

ChatGPT (OpenAI) was used to produce the structured methodological reviews, written from the perspective of an Austrian university data protection officer, that guided the revisions between versions 0.1, 0.2, and 0.3.

The requirements, design decisions, legal framing, and final content of the framework and of this technical note remain the responsibility of the author. All factual and legal claims have been reviewed by the author; nonetheless, as with any document produced with AI assistance, readers are advised to independently verify legal references before relying on them in an institutional context.

---

## Citation

Holubar, P. (2026). Austrian University DPIA Generator for AI Systems (Version 0.3). Zenodo. DOI: [to be assigned].

## Related Work

Holubar, P. (2026). University AI Assessment Tool (Version 0.3). Zenodo. DOI: 10.5281/zenodo.20258614.

## Keywords

Data Protection Impact Assessment; DPIA; GDPR; AI Governance; EU AI Act; Higher Education; Research Governance; University Governance; Austria; Compliance; Privacy; Artificial Intelligence; Works Council; Labour Constitution Act; Schrems II; Academic Freedom.